

Third-Party & Supply-Chain Risk Management Policy

1. Purpose and Scope

Hewlett Packard Enterprise (HPE) depends on an extensive ecosystem of third parties - cloud providers such as AWS and Microsoft Azure, enterprise software vendors including SAP and Salesforce, identity providers like Okta, and hardware manufacturing partners such as Foxconn. This Third-Party and Supply-Chain Risk Management Policy establishes the requirements governing how HPE identifies, assesses, and oversees every vendor, supplier, service provider, and outsourcing arrangement across its supply chain. It applies to all business units, procurement teams, and personnel who engage, contract with, or manage external parties on behalf of HPE.

The objective of this program is to ensure that risks introduced by third parties - including cybersecurity, operational, financial, privacy, regulatory, and reputational risks - are managed consistently throughout the entire vendor lifecycle, from onboarding through offboarding.

2. Governance and Ownership

The Third-Party Risk Management (TPRM) function, operating under the Chief Information Security Officer and Chief Procurement Officer, owns this policy. Business owners act as relationship managers accountable for the day-to-day performance and risk posture of each supplier they sponsor. The TPRM Committee reviews escalations, approves exceptions, and reports aggregate supply-chain risk to executive leadership and the Board Risk Committee on a quarterly basis.

3. Vendor Inventory and Identification

HPE maintains a centralized vendor inventory (the authoritative supplier catalog) that records every third party with access to HPE systems, data, facilities, or that delivers goods and services material to operations. No engagement may proceed until the vendor is formally identified and registered on this list. The inventory captures ownership, data classification handled, spend, contract dates, and the assigned risk tier. Procurement reconciles the catalog against accounts-payable records at least annually to detect unregistered or "shadow" vendors.

4. Vendor Tiering and Criticality Classification

Every third party is subject to risk-based tiering. During onboarding, TPRM performs an inherent-risk classification that categorizes the supplier by criticality using factors such as data sensitivity, system access, business dependency, regulatory exposure, and substitutability. This risk-rating produces a tier:

- Tier 1 - Critical: Vendors whose failure would materially disrupt HPE operations or expose regulated/confidential data (e.g., AWS, Microsoft, Okta, Foxconn).
- Tier 2 - Important: Vendors handling significant but recoverable services (e.g., SAP, Salesforce).
- Tier 3 - Limited: Vendors with minimal access or impact.

The assigned tier determines the depth of due diligence, contractual rigor, and monitoring frequency applied.

5. Due Diligence and Assessment

Before contract execution, each vendor undergoes due diligence proportionate to its tier. HPE issues

a standardized security and privacy assessment questionnaire (aligned to ISO 27001, SOC 2, and NIST frameworks) and reviews supporting evidence such as audit reports, penetration-test summaries, financial statements, and certifications. Tier 1 suppliers additionally receive an on-site or virtual control review and, where applicable, a supply-chain integrity assessment covering hardware provenance and counterfeit prevention. Assessment findings must be remediated or formally risk-accepted before onboarding is approved.

6. Contractual Controls

All third-party relationships must be governed by written contracts and agreements that codify HPE's risk requirements. Contracts must include, at minimum: data protection and confidentiality clauses, defined service-level agreements (SLAs) with performance and availability commitments, breach-notification obligations, compliance with applicable laws, a right-to-audit clause enabling HPE to verify controls, and clearly documented exit and termination provisions. Legal and TPRM jointly approve deviations from standard clauses. SLAs are tracked against measured performance, and persistent breaches trigger escalation.

7. Subcontractor and Fourth-Party Oversight

Vendors frequently rely on their own subcontractors, creating fourth-party and nth-party dependencies that can propagate risk into HPE's supply chain. Contracts must require suppliers to disclose material subcontractors, flow down equivalent security and privacy obligations, and obtain HPE approval before engaging fourth parties that handle HPE data. TPRM maps concentration risk - for example, multiple critical vendors depending on the same underlying cloud infrastructure - and factors this exposure into resilience planning.

8. Ongoing and Continuous Monitoring

Third-party risk is managed continuously, not only at onboarding. HPE performs periodic reassessment of each vendor on a cadence driven by tier - Tier 1 annually, Tier 2 biennially, and Tier 3 on a risk-triggered basis. Continuous monitoring includes external security-rating feeds, threat-intelligence and breach alerts, SLA performance reviews, and re-issued questionnaires. Material changes - a data breach, ownership change, adverse audit finding, or degraded rating - trigger an off-cycle review and, where warranted, remediation plans or tier reclassification.

9. Exit, Termination, and Contingency Strategy

Every critical engagement must have a documented exit and transition strategy defined before onboarding. Offboarding procedures ensure secure return or destruction of HPE data, revocation of access, knowledge transfer, and orderly service migration. For Tier 1 suppliers, HPE maintains contingency and business-continuity plans - including identified alternate providers or in-sourcing options - so that termination, insolvency, or sustained SLA failure does not disrupt operations.

10. Enforcement and Review

Non-compliance with this policy may result in engagement suspension and disciplinary action. This policy is reviewed at least annually, or upon significant regulatory or business change, by the TPRM Committee.